

信息安全管理规范

第一章 账号与口令

所有信息系统账号实行实名制，一人一号，禁止共用账号。离职人员账号在离职手续办结当日注销；转岗人员账号在原岗位权限清理完成后重新授权，不得出现「原权限未撤、新权限已给」的叠加状态。特权账号（root、sa、admin 等）须纳入堡垒机统一管理，禁止直接登录，所有操作留屏留痕。

口令复杂度要求：长度不少于十二位，须同时包含大写字母、小写字母、数字与特殊符号四类字符中的至少三类，且不得包含用户名、工号、连续三位以上键盘序（如 qwe、123）或常用弱口令。口令有效期九十天，系统提前七天开始提醒，到期未修改的账号将被自动锁定，需通过服务台人工解锁。

每个系统须独立口令，禁止跨系统复用。禁止在聊天工具、邮件正文、便签纸、代码注释或配置文件明文注释中记录口令。确需共享凭据的场景（如后台运维账号、第三方对接账号），必须使用公司统一的密码管理平台，并开启双人审批与操作留痕。

1.1 多因素认证

以下系统强制启用多因素认证：VPN、堡垒机、云平台控制台、代码仓库管理后台、财务系统、以及任何可通过公网访问的管理入口。多因素认证的第二因素优先使用硬件令牌或手机 App 动态码，短信验证码仅作为备选，且不得用于 L4 级数据的访问控制。

第二章 数据分级与保护

公司数据按敏感程度分为四级，不同级别对应不同的存储、传输与外发要求。数据级别由数据产生部门初定，信息安全部门复核，级别调整须留存变更记录与调整理由。对外提供数据前必须确认级别，不得以「应该不敏感」为由跳过定级。

级别	典型数据	传输要求	外发审批
L1 公开	宣传材料、公开财报	无限制	无需审批
L2 内部	内部通知、一般流程文档	公司内网	部门负责人
L3 保密	客户名单、合同、报价单	加密通道	部门负责人 + 法务
L4 绝密	核心源码、未公开财务数据	专用加密通道	总经理办公会

2.1 外发管控

L3

及以上数据禁止通过个人邮箱、个人网盘或即时通讯工具外发。确因业务需要的，须走公司统一的外发审批流程，由信息安全部门生成带水印与有效期的受控链接。链接有效期最长七个自然日，到期自动失效且不可续期；确需延长的必须重新走审批，不得原地延期。

所有外发行为均被审计系统记录，记录内容包括发送人、接收人、文件摘要、文件大小与发送时间。审计日志保存三年，仅信息安全负责人与内审部门可查阅，查阅行为本身也被记录，避免审计权限被滥用。

2.2 数据销毁

存储介质报废前须执行数据擦除，L3

及以上数据所在介质必须进行物理销毁并留存销毁记录与影像。退役终端在移交资产部门前须完成磁盘加密密钥的吊销与全盘擦除，不得以「已删除文件」替代擦除。

第三章 终端与网络安全

办公终端须安装公司统一的终端防护软件，禁止自行卸载、关闭实时防护或将其加入白名单例外。终端磁盘须全盘加密，笔记本离开办公场所时必须启用；办公区无线网络分为员工网与访客网，访客网禁止访问任何内部系统。

禁止在办公终端上安装未授权的远程控制软件与个人网盘客户端。因业务需要安装第三方工具时，须提交软件白名单申请，由信息安全部门评估后统一分发，不得自行下载安装。

3.1 安全事件上报

发现疑似安全事件（包括收到钓鱼邮件、设备丢失、异常登录提醒、账号被非本人操作）须在两小时内向信息安全部门报告，不得自行处置、不得隐瞒、也不得在内部群随意扩散细节。信息安全部门接到报告后须在四小时内完成初步判定并给出处置建议。

主动上报且未造成实际损失的，不予追责；隐瞒不报或拖延上报造成损失的，从重处理。这条「上报免责」原则是整套制度能运转的前提——如果上报就会被追责，员工的最优策略就变成掩盖。